Seguridad en Sistemas, Aplicaciones y el Big Data

Tema 9. Seguridad en la nube

Índice

Esquema

Ideas clave

9.1. Introducción y objetivos

9.2. Componentes de Azure

9.3. Azure Entra ID

9.4. Administración de usuarios y grupos en Azure AD

9.5. Configuración y administración

9.6. Referencias bibliográficas

A fondo

Protección de usuarios de Azure Entra ID con Multi-Factor Authentication

Protección de la aplicación con OpenID Connect y Azure AD

Acceso seguro a las aplicaciones con servicios de identidad de Azure

Introducción al firewall de aplicaciones web de Azure

Test

© Universidad Internacional de La Rioja (UNIR)

Esquema

SEGURIDAD EN LA NUBE

Objetivo: conocer y estudiar los principales subsistemas que se usan en Microsoft Azure para implementar la seguridad de usuarios y recursos en la nube.

COMPONENTES MICROSOFT AZURE	AZURE ENTRA ID	PROTECCIÓN DE SECRETOS CON K VAULT
Se analizan los principales componentes, como recursos, suscripciones, grupos de recursos, etc.	Se explica el concepto, cómo se relaciona con Active Directory de Windows y cómo crear usuarios y grupos.	Servicio en la nube centralizado para almacenar secretos de aplicación, con claves de cifrado, certificados y *tokens* lado servidor.

9.1. Introducción y objetivos

Existen tres modelos de implementación de **servicios informáticos** en la nube: **nube pública, nube privada y nube híbrida.** Cada modelo de implementación posee distintas características que hay tener en mente a la hora de migrar hacia la nube. **Microsoft Azure** es una de las tecnologías de implementación de servicios en la nube más extendidas. Según DocsMicrosoft (2022), la página de los **tres modelos principales** son los que se mencionan en la Tabla 1:

Nube pública	Los servicios se ofrecen a través de la red **Internet pública** y están disponibles para cualquiera que quiera comprarlos. Los recursos de nube, como los servidores y el almacenamiento, son propiedad de un proveedor de servicios en la nube de terceros, que los explota y los distribuye a través de Internet.
Nube privada	Una nube privada consta de recursos informáticos que determinados usuarios de una empresa u organización usan en **exclusiva.** Una nube privada puede estar ubicada físicamente en el centro de datos local (entorno local) de la organización o estar hospedada por un proveedor de servicios de terceros.
Nube híbrida	Una nube híbrida es un entorno informático que **combina una nube pública y una nube privada,** lo que permite compartir datos y aplicaciones entre ellas.

Tabla 1. Tres modelos principales de la nube. Fuente: adaptado de DocsMicrosoft, 2022.

Según Azure los entornos en la nube ofrecen varias **ventajas** en comparación con los entornos físicos, estas se pueden observar en la Tabla 2, basada en DocsMicrosoft (2022).

© Universidad Internacional de La Rioja (UNIR)

Alta disponibilidad	En función del contrato de nivel de servicio (SLA) que elija, las aplicaciones basadas en la nube pueden proporcionar una experiencia de usuario continua sin tiempo de inactividad perceptible, aunque se produzcan errores.
Escalabilidad	Las aplicaciones en la nube se pueden escalar vertical y horizontalmente. **El escalado vertical** para aumentar la capacidad de proceso mediante la incorporación de RAM o CPU adicionales a una máquina virtual. **El escalado horizontal** aumenta la capacidad de proceso mediante la adición de instancias de recursos, como la incorporación de máquinas virtuales a la configuración.
Elasticidad	Puede configurar aplicaciones basadas en la nube para aprovechar el escalado automático, de forma que las aplicaciones siempre dispondrán de los recursos que necesitan.
Agilidad	Implemente y configure rápidamente los recursos basados en la nube a medida que cambian los requisitos de la aplicación.
Distribución geográfica	Puede implementar aplicaciones y datos en centros de datos regionales de todo el mundo, lo que garantiza que sus clientes siempre tengan el mejor rendimiento de su región.
Recuperación ante desastres	Al usar los servicios de copia de seguridad basados en la nube, la replicación de datos y la distribución geográfica, podrá implementar las aplicaciones con la seguridad de saber que los datos están protegidos en caso de que se produzca un desastre.

Tabla 2. Ventajas de los entornos de la nube en comparación con los físicos. Fuente: DocsMicrosoft, 2022.

Veremos los conceptos y subsistemas necesarios para el diseño e implementación de la seguridad en la nube tomando como referencia la tecnología **Microsoft Azure.** Es necesario explicar el concepto de «**Azure Entra ID**» y la administración de usuarios y grupos o el acceso seguro a las aplicaciones con los servicios de identidad de Azure entre otros.

Los objetivos al estudiar esto son:

- Aprender el concepto de Azure Active Directory.
- Aprender los conceptos de «Administración de usuarios» y «Grupos en Azure Entra ID».

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

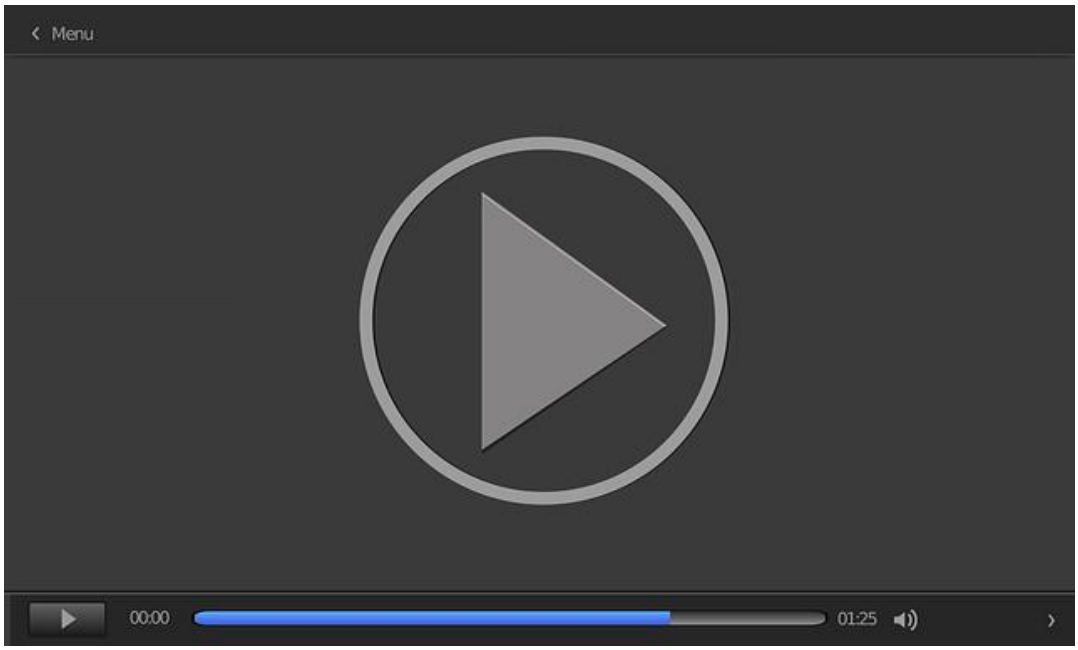
- Conocer cómo es el acceso seguro a las aplicaciones con los servicios de identidad de Azure.
- Saber los aspectos de la configuración de secretos con Key Vault.
- Aprender cómo proteger las aplicaciones con con OpenID Connect y OAuth2.
- Conocer cómo proteger a los usuarios con Azure Entra ID y Multi Factor.
- Aprender a proteger los recursos de Azure con el control de acceso basado en roles de Azure (Azure RBAC).

© Universidad Internacional de La Rioja (UNIR)

9.2. Componentes de Azure

Como paso previo a analizar los conceptos y algunos de los subsistemas relacionados con la implementación de la seguridad en Azure, es necesario describir los principales componentes de Azure.

En el vídeo *Microsoft Azure* se muestran los elementos principales de la arquitectura.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=84841ad7-a658-4fc0-86f9-adcb011b0fac

La **estructura organizativa de los recursos en Azure,** tal como se muestra en la página de DocsMicrosoft (2022), consta de **cuatro niveles que presentamos en la Tabla 3**.

© Universidad Internacional de La Rioja (UNIR)

Recursos	Los recursos son instancias de servicios que puede crear, como máquinas virtuales, almacenamiento o bases de datos SQL.
Grupos de recursos	Los recursos se combinan en grupos de recursos, que actúan como contenedor lógico en el que se implementan y administran recursos de Azure como aplicaciones web, bases de datos y cuentas de almacenamiento.
Suscripciones	Una suscripción agrupa las cuentas de usuario y los recursos que han creado esas cuentas de usuario. Para cada suscripción, hay límites o cuotas en la cantidad de recursos que se pueden crear y usar. Las organizaciones pueden usar las suscripciones para administrar los costos y los recursos creados por los usuarios, equipos o proyectos.
Grupos de administración	Estos grupos le ayudan a administrar el acceso, las directivas y el cumplimiento de varias suscripciones. Todas las suscripciones de un grupo de administración heredan automáticamente las condiciones que se aplican al grupo de administración.

Tabla 3. Estructura organizativa de los recursos en Azure. Fuente: adaptado de la página de DocsMicrosoft, 2022.

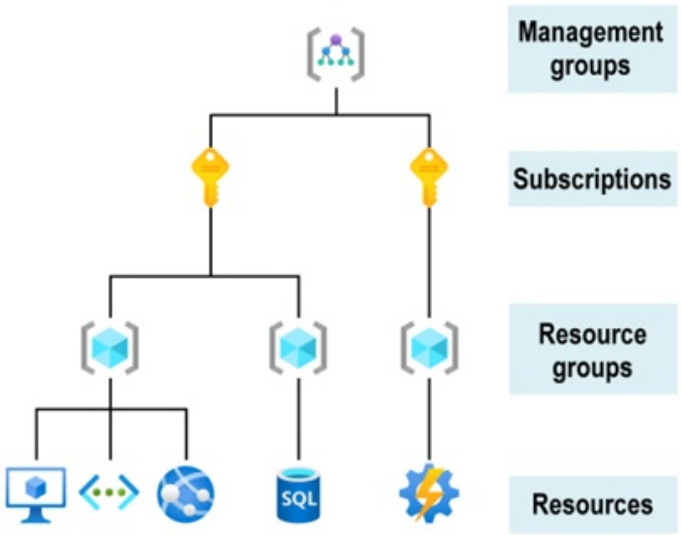


Figura 1. Estructura organizativa de Azure. Fuente: página de DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Cuando se elimina un grupo de recursos, además se eliminan todos los que contiene. La organización de los **recursos del ciclo de vida** es útil en entornos que no son de producción, donde se puede probar y rechazar posteriormente. Los grupos de recursos son el ámbito para aplicar el control de acceso basado en roles (RBAC). Al aplicar permisos RBAC a un grupo de recursos se puede administrar y restringir fácilmente el acceso.

Azure Resource Manager

Permite configurar y administrar Azure. Proporciona una capa administrativa que posibilita crear, actualizar y eliminar recursos de la cuenta de Azure. Permite Administrar el control de acceso, bloqueos y etiquetas para maximizar la protección y revisar el conjunto de recursos una vez implementados.

Cuando un usuario realiza un envío de solicitud de una herramienta, una API o un SDK de Azure, el componente Resource Manager es el que la recibe. Posteriormente, autentica y aprueba la solicitud.

Finalmente, Resource Manager envía una solicitud al servicio de Azure, que realiza la acción solicitada. Todas las solicitudes son manejadas por la misma API, por lo que se mostrarán los resultados y la funcionalidad consistentes en los diferentes servicios o herramientas. La Figura 2 muestra el rol del administrador de recursos en el manejo de solicitudes de Azure.

© Universidad Internacional de La Rioja (UNIR)

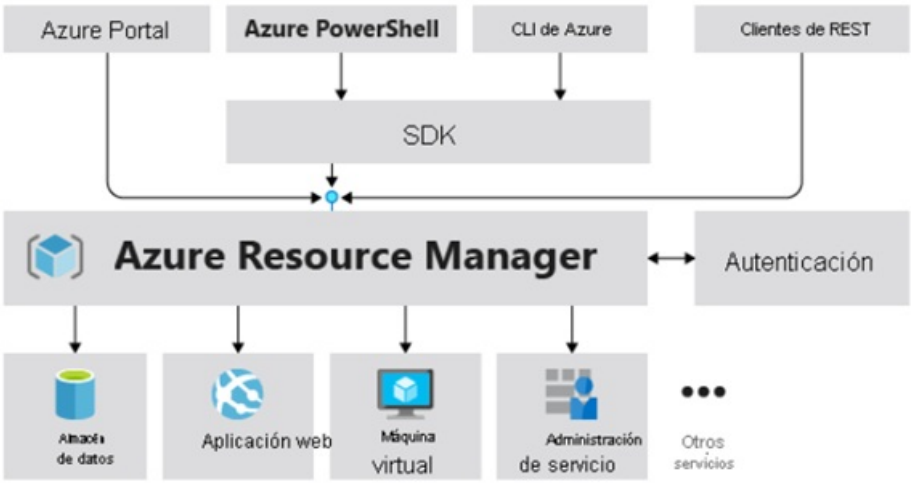


Figura 2. Azure Resource Manager. Fuente: página de DocsMicrosoft, 2022.

Además de que todas las funcionalidades son accesibles en Azure Portal, también son accesibles usando PowerShell, la CLI de Azure, las API REST y los SDK de cliente. Las funcionalidades que inicialmente están disponibles mediante las API se incluirán en el portal a los seis meses de su disponibilidad inicial.

© Universidad Internacional de La Rioja (UNIR)

Suscripciones de Azure

Para usar Azure se necesita una suscripción. Estas proporcionan acceso autenticado y autorizado a los productos y servicios de Azure. Además, le posibilita el aprovisionamiento de los recursos. Una unidad lógica o conjunto de servicios de Azure asociados con su cuenta es una suscripción, que es una identidad en Azure Entra ID (Azure AD) o un directorio de confianza de Azure AD.



Figura 3. Subscripciones en Azure. Fuente: página de DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Cualquier cuenta puede contener **una o más suscripciones** con diferentes modelos de pago y políticas de control de acceso. Se puede utilizar una suscripción de Azure para establecer límites en sus productos, servicios y recursos. Según DocsMicrosoft (2022) hay dos tipos de límites de suscripción:

Límite de facturación	Este tipo de suscripción determina cómo se factura una cuenta de Azure por el su uso. Puede crear varias suscripciones para diferentes tipos de requisitos de facturación. Azure genera facturas e informes de facturación independientes para cada suscripción, de modo que pueda organizar y administrar los costos.
Límite de control de acceso	Azure aplica las directivas de administración de acceso en el nivel de suscripción, por lo que puede crear suscripciones independientes para reflejar distintas estructuras organizativas. Por ejemplo, dentro de una empresa hay diferentes departamentos a los que se les puede aplicar distintas directivas de suscripción. Este modelo de facturación le permite administrar y controlar el acceso a los recursos que los usuarios aprovisionan con suscripciones específicas.

Tabla 4. Dos tipos de límites de suscripción de Azure. Fuente: adaptado de DocsMicrosoft, 2022.

Grupos de administración de Azure

Si su empresa posee una gran cantidad de suscripciones, es posible que se requiera una forma de administrar eficazmente el acceso, la política o directiva y el grado de cumplimiento de esas suscripciones. La administración por grupos de Azure proporciona un nivel de ámbito más allá de las suscripciones. Estas se organizan en contenedores denominados grupos de administración y los términos de gobierno se aplican dichos grupos.

© Universidad Internacional de La Rioja (UNIR)

Todas las suscripciones en un determinado grupo de administración heredarán de forma automática las condiciones que se aplican al mencionado grupo. Los grupos de administración brindan el servicio a gran escala a nivel de organización, independientemente del tipo de suscripción adquirido. Todas las suscripciones de un grupo administrativo deben tener confianza con el mismo inquilino de Azure AD. Por ejemplo, puede aplicar una política o directivas a un grupo de administración que limite las regiones a disposición para crear máquinas virtuales. Esta política se aplica a todos los grupos administrativos, sus suscripciones y sus recursos, lo que le permite crear solo máquinas virtuales en esta región.

Grupos de administración y suscripciones: jerarquía

Puede crear una estructura muy flexible en cuanto a los grupos de administración y las suscripciones con el objetivo de organizar los recursos jerárquicamente para el acceso unificado y la administración de políticas o directivas. La Figura 4 muestra un ejemplo del uso de un grupo de administración para crear una jerarquía de administración.

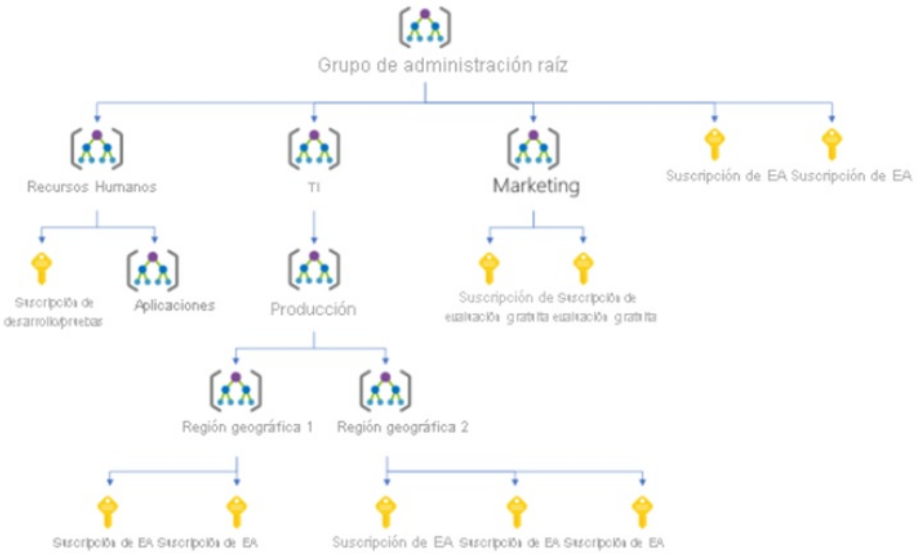


Figura 4. Grupos de Administración en Azure. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

9.3. Azure Entra ID

Es evidente que comparten un nombre similar, pero Azure AD no es una versión en la nube de Windows Server Active Directory. Tampoco pretende reemplazar completamente la instancia de Active Directory local. Si se utiliza el servidor de Windows AD, puede conectarse con Azure AD y extender su directorio a Azure. Este método posibilita a los usuarios acceder a recursos locales y basados en la nube utilizando las mismas credenciales. Los usuarios también pueden usar Azure AD por separado de Windows AD.

Las pequeñas empresas pueden usar Azure AD como su único servicio de directorio para controlar el acceso a productos y aplicaciones SaaS, por ejemplo: Microsoft 365, Salesforce y Dropbox. Hay que tener en consideración que este método no suministra un modelo de administración completamente centralizado (por ejemplo, una computadora local con Windows autenticada con credenciales locales). Los usuarios pueden crear aplicaciones que usan Azure AD para proporcionar mecanismos de autenticación y autorización que los usuarios pueden administrar en un solo sitio.

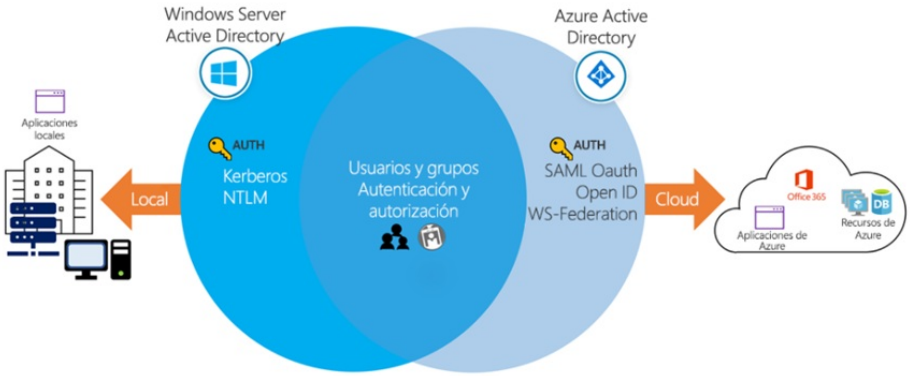


Figura 5. Active Directory y Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Directorios, suscripciones y usuarios

Microsoft dispone actualmente de varios servicios en la nube, como **Azure, 365, Intune y Dynamics 365,** y cualquiera puede usar Azure AD para definir usuarios y crear una política de acceso.

Cuando una organización o compañía realiza una suscripción en uno de estos servicios se le proporciona un directorio predeterminado, que es una instancia de Azure AD. Dicho directorio dispone de los usuarios y grupos que pueden acceder a los servicios adquiridos por la organización. Este directorio predeterminado se llama **inquilino.** Este está asociado a la organización y al directorio predeterminados, es decir, el inquilino representa a la organización y al directorio.

Las suscripciones de Azure son entidades de facturación y constituyen una frontera de seguridad. Recursos como máquinas virtuales, sitios web y bases de datos están asociados con una única suscripción. Una suscripción determinada también tiene un propietario de cuenta único que es responsable de los costos incurridos por los recursos de la suscripción. Si su empresa desea cargar la suscripción a otra cuenta, dicha suscripción puede transferirse.

Cada suscripción está asociada a un solo directorio perteneciente a Azure AD. Asimismo, distintas subscripciones pueden confiar en un mismo directorio, pero cada una solo confía en un único directorio. Puede agregar usuarios y grupos a varias suscripciones para permitir que los usuarios creen, controlen y accedan a los recursos. Al agregar un usuario, este debe ser conocido en el directorio correspondiente, como se puede observar en la Figura 6.

© Universidad Internacional de La Rioja (UNIR)

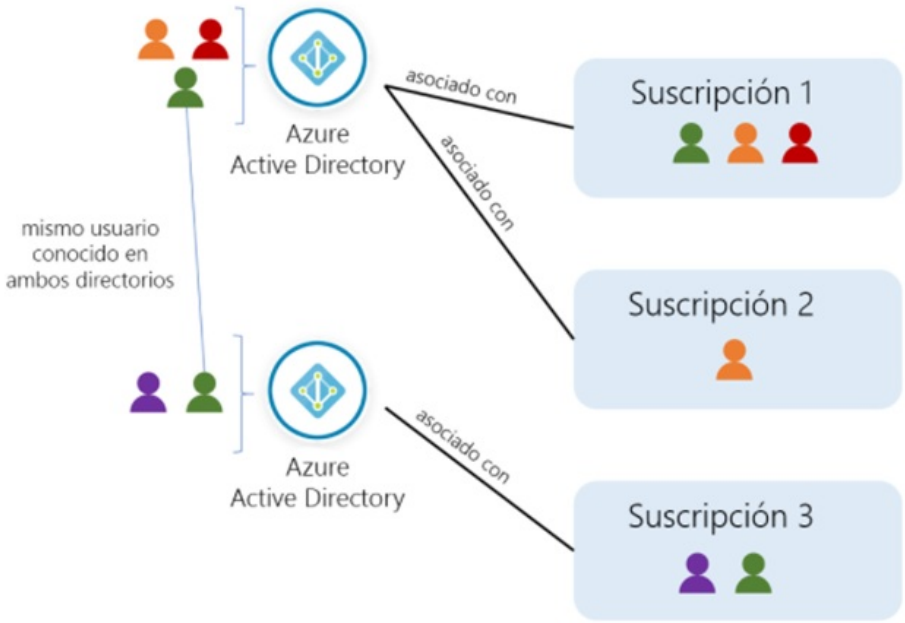


Figura 6. Active Directory y Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

9.4. Administración de usuarios y grupos en Azure AD

Crear usuarios

Se necesita una cuenta de usuario Azure para poder acceder a sus recursos. Dicha cuenta contiene toda la información necesaria para autenticar al usuario en el inicio de sesión. Después de autenticarse, Azure AD genera un *token* de acceso para otorgar permisos al usuario y determinar a qué recursos tendrá acceso. Se debe utilizar el panel de Azure Entra ID en Azure Portal para trabajar con las cuentas de usuario.

Únicamente se puede trabajar con una carpeta a la vez, pero es posible cambiar de directorio mediante el panel **Directorio+subscripción.** La barra de herramientas del panel también dispone de un botón Cambiar-directorio que le permite cambiar fácilmente cambiar entre directorios. Para visualizar los usuarios disponibles en Azure AD, seleccionar Usuarios en Administración en la ventana del menú de la izquierda. Se muestra el panel Todos los usuarios. Tenga en cuenta las columnas: Tipo de usuario y Emisor de identidad, como se observa en la Figura 7.

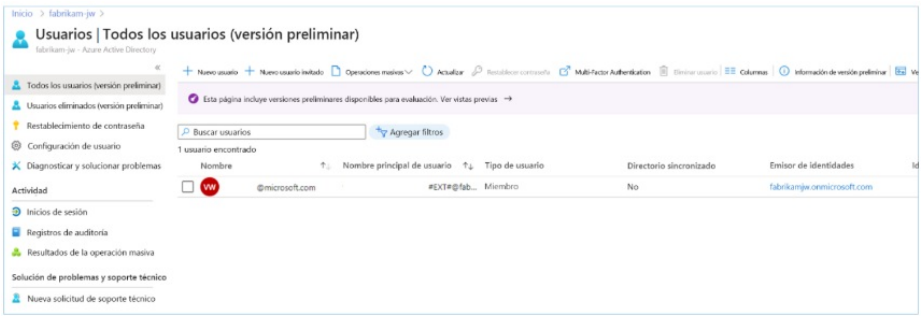


Figura 7. Usuarios Azure AD. Fuente: página de DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Normalmente, Azure AD define usuarios de tres maneras, según DocsMicrosoft (2022):

Identidades de nube	Estos usuarios solo existen en Azure AD. Algunos ejemplos son las cuentas de administrador y los usuarios que usted mismo administra. Su origen es Azure Active Directory o Azure Active Directory externo si el usuario está definido en otra instancia de Azure AD, pero necesita acceso a los recursos de la suscripción controlados por este directorio. Cuando estas cuentas se quitan del directorio principal, se eliminan.
Identidades sincronizadas con Active Directory	Estos usuarios existen en una instancia de Active Directory local. Una actividad de sincronización que se realiza a través de Azure AD Connect lleva a estos usuarios a Azure. Su origen es Windows Server AD.
Usuarios invitados	Estos usuarios se encuentran fuera de Azure. Algunos ejemplos son las cuentas de otros proveedores de nube y cuentas de Microsoft, como una cuenta de Xbox Live. Su origen es Usuario invitado. Este tipo de cuenta es útil cuando los proveedores externos o los contratistas necesitan acceso a los recursos de Azure. Una vez que se puede prescindir de ellos, la cuenta correspondiente y todo el acceso del que disfrutan se puede quitar.

Tabla 5. Tres tipos de usuarios. Fuente: adaptado de DocsMicrosoft, 2022.

Azure AD Connect es un servicio que posibilita sincronizar su instancia de Active Directory con la instancia de Azure AD. De esta forma, la mayoría de los clientes comerciales añaden usuarios a su directorio. La ventaja de este enfoque es que los usuarios pueden acceder a recursos locales y basados en la nube mediante el inicio de sesión único (SSO).

Se puede añadir nuevos usuarios de forma manual desde el portal de Azure. Esta es la forma más sencilla de añadir un número limitado de usuarios. Se debe poseer la función/rol de administrador de usuarios para poder realizarlo. Si se debe añadir una gran cantidad usuarios, es preferible utilizar herramientas de línea de comandos. Puede agregar usuarios basados en la nube ejecutando el comando **Azure PowerShell New-AzureADUser.**

© Universidad Internacional de La Rioja (UNIR)

Creación de un grupo

Los grupos de Azure AD ayudan a organizar a los usuarios con una administración de permisos más sencilla. Permiten a los propietarios de recursos (o propietarios de directorios de Azure AD) asignar una serie de permisos a todos los miembros del grupo a la vez evitando tener que hacerlo de forma individual. Los grupos posibilitan establecer fronteras de seguridad, añadir y eliminar usuarios específicos y permitir o denegar el acceso con un mínimo esfuerzo. Además, Azure AD posibilita establecer la unión a un grupo en función de reglas como el departamento de trabajo u ocupación del usuario.

Según DocsMicrosoft (2022), Azure AD posibilita definir **dos tipos de grupos:**

Grupos de seguridad	Son los más comunes y se usan para **administrar el acceso de miembros** y del equipo a los recursos compartidos de un grupo de usuarios. Por ejemplo, puede crear un grupo de seguridad relativo a una directiva de seguridad específica. De esta forma, puede conceder una serie de permisos a todos los miembros a la vez, en lugar de tener que agregarlos a cada miembro individualmente. **Esta opción requiere un administrador de Azure AD.**
Grupos de Microsoft 365	Estos grupos brindan oportunidades de **colaboración** al conceder acceso a los miembros a un correo compartido, calendarios, archivos, un sitio de SharePoint y mucho más. Esta opción también permite ofrecer acceso al grupo a personas que estén fuera de la organización. Está disponible para los usuarios, así como para los administradores.

Tabla 6. Tipos de grupos según Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)



Figura 8. Grupos en Azure AD. Fuente: DocsMicrosoft, 2022.

Cuando se crea un grupo en Azure AD, se tienen las mismas opciones que cuando se crean los usuarios. Azure Portal es la manera más sencilla para la creación un grupo. Se tiene que seleccionar el tipo de grupo (seguridad o Microsoft 365) y especificar un nombre de grupo, una descripción y tipo de unión o pertenencia únicos. También puede utilizarse Azure PowerShell para agregar grupos mediante el comando New-AzureADGroup, como se muestra a continuación.

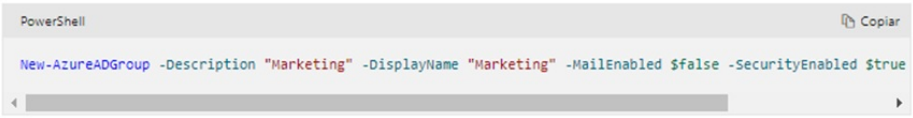


Figura 9. Adición de grupos en Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Roles

Según DocsMicrosoft (2022):

> «Azure AD proporciona varios roles integrados para cubrir los escenarios de seguridad más comunes. Para entender cómo funcionan los roles, vamos a examinar cuatro roles que son válidos en cualquier tipo de recurso:

- **Propietario,** que tiene acceso total a todos los recursos, incluido el derecho a delegar este acceso a otros.
- **Colaborador,** que puede crear y administrar todos los tipos de recursos de Azure, pero no conceder acceso a otros.
- **Lector,** que puede ver los recursos existentes de Azure.

> Administrador de acceso de usuario: permite administrar el acceso de los usuarios a los recursos de Azure».

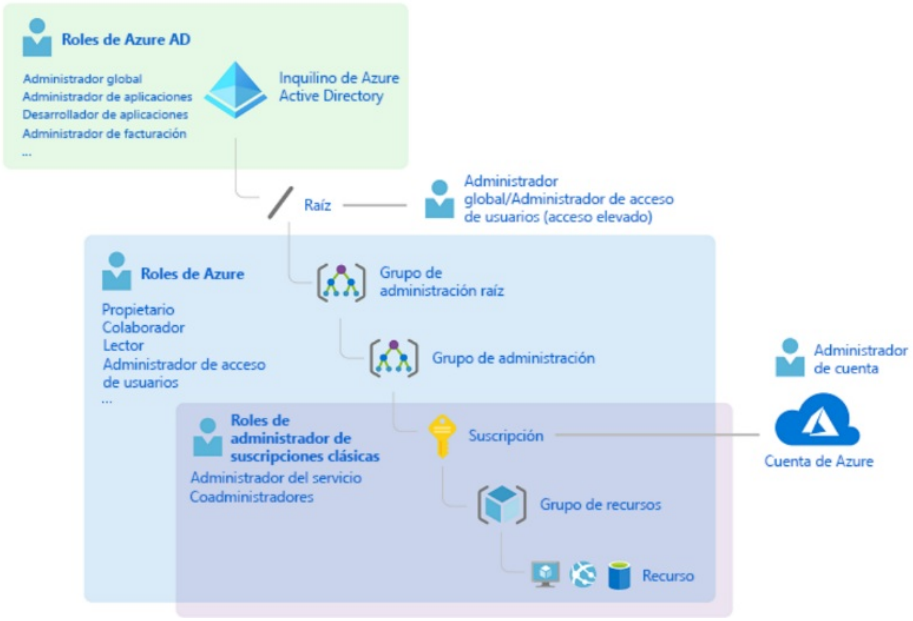


Figura 10. Visión de Roles en Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

DocsMicrosoft (2022), también afirma lo siguiente:

«Estos son algunos de los escenarios que puede implementar con Azure RBAC.

- Permitir que un usuario administre las máquinas virtuales de una suscripción y que otro usuario administre las redes virtuales
- Permiso a un grupo de administradores de base de datos para administrar bases de datos SQL en una suscripción
- Permitir que un usuario administre todos los recursos de un grupo de recursos, como las máquinas virtuales, los sitios web y las subredes
- Permitir que una aplicación acceda a todos los recursos de un grupo de recursos».

Una función o rol es un conjunto de características y propiedades definidas en un archivo JSON. La definición de este rol incluye: nombre, identificador y descripción. Además, se incluyen permisos relativos a **Actions**, que se pueden otorgar, los permisos **NotActions,** que no se pueden otorgar y el **alcance o ámbito del rol**, como puede ser el acceso de escritura). P.e., el rol de propietario que incluye todas las acciones, es indicado por medio un asterisco (*). Si ninguna acción se rechaza, al incluirse todos los ámbitos, es indicado por la barra (/). Puede consultar esta información usando **cmdlet- GetAzRoleDefinitionPowerShell Owner.**

© Universidad Internacional de La Rioja (UNIR)

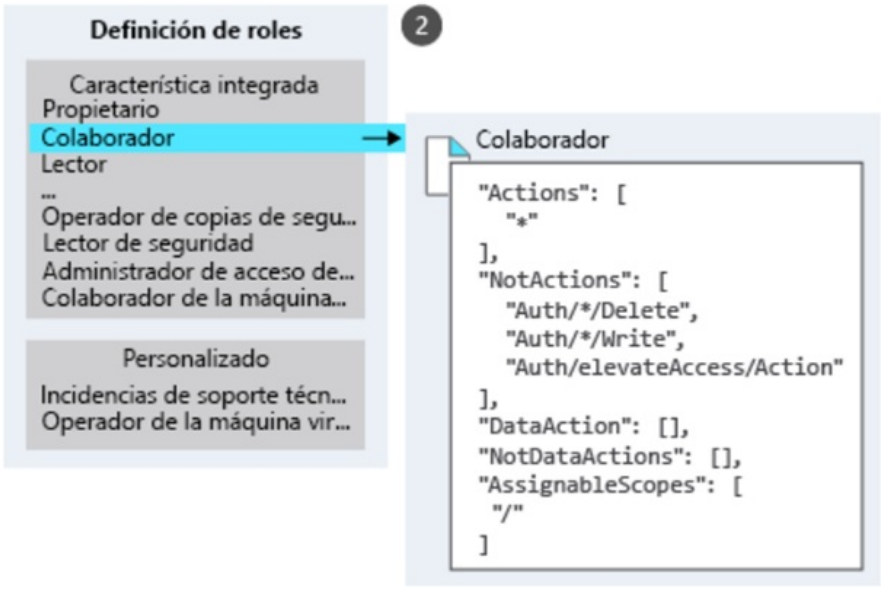


Figura 11. Roles en Azure AD. Fuente: DocsMicrosoft, 2022.



Figura 12. Roles en Azure AD. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Las características Actions y NotActions se pueden configurar para dar y denegar los permisos que requeridos de forma precisa. Estas características se presentan con el siguiente formato:

{Company}.{ProviderName}/{resourceType}/{action}.

Rol integrado	Actions	NotActions
Propietario (se permiten todas las acciones)	`*`	-
Colaborador (se permiten todas las acciones, excepto escribir o eliminar asignaciones de roles)	`*`	`Microsoft.Authorization/*/Delete`, `Microsoft.Authorization/*/Write`, `Microsoft.Authorization/*/elevateAccess/Action`
Lector (se permiten todas las acciones de lectura)	`*/read`	-

Figura 13. Roles y permisos en Azure AD. Fuente: DocsMicrosoft, 2022.

En Actions, el **operador comodín (*)** significa que la identidad de seguridad especificada para esta función o rol puede ejecutar todas las acciones. En resumen, este rol puede manejar todo, incluso acciones definidas más adelante, cuando Azure agregue nuevos tipos de recursos. Como rol lector, solo se posibilita acción de lectura. Las acciones NotActions se eliminan de Actions. Como rol de colaborador, NotActions elimina la capacidad para configurar, administrar y especificar el acceso a recursos. Con respecto a las operaciones sobre datos especificadas por las propiedades DataActions y NotDataActions, se pueden especificar independientemente de las operaciones administrativas.

Esto evita que las tareas existentes que utilizan comodines (*) accedan repentinamente a los datos. Según DocsMicrosoft (2022):

© Universidad Internacional de La Rioja (UNIR)

«Estas son las operaciones de datos que se pueden especificar con DataActions y NotDataActions:

- Leer una lista de blobs en un contenedor
- Escribir un blob de almacenamiento en un contenedor
- Eliminar un mensaje de una cola».

Únicamente se pueden añadir operaciones de datos a DataActions y NotDataActions. El proveedor de recursos determina cuál es la operación de datos habilitando la propiedad isDataAction a *true.* Los roles sin manipulación de datos pueden omitir estos atributos de su definición.

Estas acciones se comportan de forma igual a sus equivalentes para administrar. Especifique las acciones que desea que sean permitidas (o * en todos los casos) y luego proporcione una lista de acciones específicas para eliminar de la colección NotDataActions. Puedes ver la lista completa de acciones y acciones de datos en la documentación del proveedor de recursos:

Operación de datos	Descripción
`Microsoft.Storage/storageAccounts/blobServices/containers/blobs/delete`	Elimina datos de blob.
`Microsoft.Compute/virtualMachines/login/action`	Inicia sesión en una máquina virtual como un usuario normal.
`Microsoft.EventHub/namespaces/messages/send/action`	Envía mensajes a un centro de eventos.
`Microsoft.Storage/storageAccounts/fileServices/fileshares/files/read`	Devuelve un archivo o una carpeta, o bien una lista de archivos o carpetas.
`Microsoft.Storage/storageAccounts/queueServices/queues/messages/read`	Lee un mensaje de una cola.

Figura 14. Acciones sobre los datos. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Para definir las características-propiedades Actions y NotActions no es suficiente a la hora implementar un rol completamente. Además, es necesario detallar el ámbito que va a tener el rol o función. La característica AssignableScopes del rol detalla los ámbitos (suscripciones, grupos de recursos o recursos) en los que el citado rol está disponible en la relación a su asignación. Se puede posibilitar que un rol personalizado esté disponible para su asignarse únicamente en las suscripciones o los grupos de recursos que se requieran, para no saturar la experiencia de usuario con las suscripciones o grupos de recursos restantes.



Figura 15. Ámbito de un rol. Fuente: DocsMicrosoft, 2022.

Azure AD incorpora roles integrados que seguramente tienen una cobertura total de lo que se puede pretender realizar. En la medida de lo posible, es recomendable utilizar un rol integrado, no obstante, se pueden crear roles de forma personalizada, si es necesario. Un rol puede ser creado de varias formas, según DocsMicrosoft (2022):

- **Azure Portal.** Puede usar Azure Portal para crear un rol personalizado: Azure Entra ID > Roles y administradores > Nuevo rol personalizado.
- **Azure PowerShell.** Puede usar el cmdlet New-AzADMSRoleDefinition para definir un rol nuevo.

© Universidad Internacional de La Rioja (UNIR)

- **Graph API de Azure.** Se puede usar una llamada de REST a Graph API para crear un rol mediante programación.

Una vez que se ha determinado quién, qué y dónde, se puede relacionar esta información para otorgar el acceso. Una **asignación de roles** consiste en enlazar un rol con una entidad de servicio dentro de un ámbito específico con el objetivo de otorgar el acceso. Es preciso crear una asignación de roles para poder otorgar el acceso. Es necesario eliminar la asignación de roles para revocar el acceso.

En el siguiente ejemplo se muestra cómo se le asignó el **rol de colaborador** al grupo de *marketing* dentro del ámbito del grupo de recursos de ventas.



Figura 16. Asignación de un rol. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Azure AD Connect

Las organizaciones que utilizan una implementación de Windows Server Active Directory local pueden integrar a los usuarios y grupos existentes con Azure Entra ID a través del servicio independiente Azure AD Connect. Es una herramienta libre de pago que se puede instalar para sincronizar una instancia de AD local con un directorio de Azure.

Mediante Azure AD Connect se puede suministrar a los usuarios de una identidad única y común aplicaciones de Microsoft 365, Azure y SaaS integradas con Azure AD dentro de un ambiente de identidad híbrido.

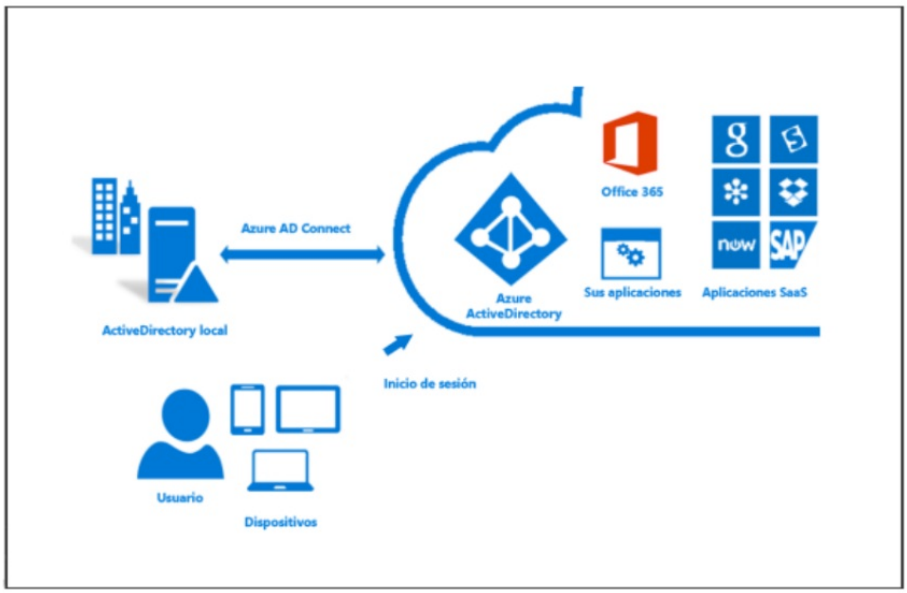


Figura 17. Azure AD Connect. Fuente: DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

DocsMicrosoft (2022), Azure AD Connect incorpora varios componentes que pueden instalarse con el objetivo de implementar un sistema de identidades híbrido:

Servicios de sincronización	Este componente es responsable de la creación de usuarios, grupos y otros objetos, así como de asegurar que la información de identidad de los usuarios y los grupos del entorno local coincidan con la de la nube.
Seguimiento del estado	Para ver esta actividad Azure AD Connect Health proporciona una supervisión sólida y una ubicación central en Azure Portal.
AD FS	La federación es una parte opcional de Azure AD Connect y puede utilizarse para configurar un entorno híbrido mediante una infraestructura local de AD FS. Las organizaciones pueden utilizar esto para abordar implementaciones complejas, como un inicio de sesión único de unión a dominio, la aplicación de la directiva de inicio de sesión de Active Directory y la autenticación multifactor mediante tarjeta inteligente o de terceros.
Sincronización de hash de contraseña	Esta característica consiste en un método de inicio de sesión que sincroniza el *hash* de la contraseña de un usuario de Active Directory local con Azure AD.
Autenticación de paso a través	Permite que se pueda usar la misma contraseña para iniciar sesión tanto en las aplicaciones basadas en la nube como en las locales. También reduce los costos del departamento de soporte técnico, ya que es menos probable que olviden cómo iniciar sesión. Esta característica supone una alternativa a la sincronización de *hash* de contraseña con la que las organizaciones pueden aplicar sus directivas de seguridad y complejidad de las contraseñas.

Tabla 7. Componentes para un sistema de entidad híbrido. Fuente: DocsMicrosoft, 2022.

La integración de directorios locales con Azure AD hace que los usuarios sean más productivos, dado que se les proporciona una identidad común para tener acceso a recursos de nube y locales. Los usuarios y las organizaciones obtienen las siguientes ventajas, según DocsMicrosoft (2022).

© Universidad Internacional de La Rioja (UNIR)

Ventajas obtenidas
Los usuarios pueden usar una única identidad para acceder tanto a aplicaciones locales como a servicios en la nube, como Microsoft 365.
Mediante una sola herramienta se proporciona una experiencia de implementación simplificada para la sincronización y el inicio de sesión.
La integración facilita las funcionalidades más novedosas para sus escenarios. Azure AD Connect sustituye las versiones anteriores de las herramientas de integración de identidades, como DirSync y Sincronización de Azure AD. Para más información, vea Identidades híbridas: comparación de las herramientas para la integración de directorios de identidades híbridas.

Tabla 8. Ventajas obtenidas por los usuarios. Fuente: adaptado de DocsMicrosoft, 2022.

Una implementación de Azure AD Connect es una tarea compleja y necesita un planeamiento inicial adecuado antes de comenzar. Microsoft dispone de una guía completa de instalación necesaria para preparar, instalar, configurar y probar la instalación de AD Connect.

© Universidad Internacional de La Rioja (UNIR)

9.5. Configuración y administración

Azure Key Vault es un servicio centralizado para custodiar secretos de aplicación como claves de cifrado, certificados y *tokens* del lado servidor. Para controlar los secretos de aplicación, Key Vault los guarda en una única ubicación central y posibilita un acceso seguro, gestión de permisos y registro de accesos.

Según la página de DocsMicrosoft (2022), «Azure Key Vault se usa tres conceptos principales en cualquier instancia: almacenes, claves y secretos.

Almacenes

Azure Key Vault se utiliza para construir contenedores seguros llamados almacenes. Los almacenes posibilitan minimizar que se pierda información de seguridad centralizando el almacenamiento de los secretos de las aplicaciones. Las empresas necesitarán almacenes de claves. Un almacén de claves es un conjunto de claves criptográficas y datos protegidos criptográficamente, llamados «secretos», administrados por una o varias personas (las mínimas necesarias).

Los almacenes de claves contienen los grupos lógicos de claves y secretos de la empresa que se van a administrar conjuntamente. Serían como los directorios del sistema de archivos controlando y registrando el acceso a toda la información almacenada. Se pueden administrar a través de herramientas como Azure PowerShell, la CLI de Azure, la API REST o Azure Portal.



Figura 18. Creación de almacenes. Fuente: página de DocsMicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Claves

Una clave específica dentro de un almacén de claves es un recurso criptográfico que tiene uso concreto, como las **claves asimétricas** que se usan para SQL Server TDE (cifrado de datos transparente) o copia de seguridad cifrada.

Las aplicaciones no poseen acceso directo a las claves almacenadas una vez que se agregan a un almacén de claves. Tienen que utilizar las claves llamando a métodos de criptografía en el servicio Key Vault que realiza la operación solicitada dentro de su ámbito de protección. Nunca se tiene acceso directo a las claves por parte de la aplicación.

Una clave puede pertenecer a una sola instancia o tener versiones. En el último caso, una clave es un objeto con una clave principal (activa) y una colección de varias claves secundarias creadas cuando se renuevan. Key Vault permite claves asimétricas (RSA 2048). Las aplicaciones pueden usarlas para cifrar o firmar datos.

Según DocsMicrosoft (2022), existen dos variantes de claves de Key Vault: con protección por *hardware* y con protección por *software.*

© Universidad Internacional de La Rioja (UNIR)

Claves protegidas por *hardware*	El servicio Key Vault admite el uso de módulos de seguridad de *hardware* (HSM) que proporcionan un entorno protegido y resistente a manipulaciones para el procesamiento criptográfico y la generación de claves. Azure tiene HSM dedicados validados en nivel 2 de FIPS 140-2 que Key Vault usa para generar o almacenar claves. Estas claves respaldadas por HSM siempre se bloquean al límite del HSM. Cuando se solicita al servicio Key Vault que descifre o firme con una clave, la operación se realiza dentro de un HSM. Puede importar claves desde HSM propios y transferirlos a Key Vault sin salir del límite del HSM. Con frecuencia este escenario se conoce también como Aportar tu propia clave o BYOK.
Claves protegidas con *software*	Key Vault también puede generar y proteger claves mediante algoritmos RSA y ECC basados en software. Por lo general, las claves protegidas por software ofrecen la mayoría de las características que las protegidas con HSM, excepto la garantía del nivel 2 de FIPS 140-2: ▸ La clave sigue aislada de la aplicación (y Microsoft) en un contenedor que administra personalmente. ▸ Se almacena en reposo cifrado mediante HSM. ▸ Puede supervisar el uso mediante registros de Key Vault.

Tabla 9. Variantes de claves de Key Vault. Fuente: adaptado de la página de DocsMicrosoft, 2022.

Secretos

Los secretos son conjuntos de datos (menos de 10K) protegidos por una clave creada por HSM generada con el almacén de claves. Permiten hacer más sencilla la tarea de la persistencia de los datos sensibles, las aplicaciones tienen: claves de almacenamiento, certificados, cadenas de conexión SQL, claves de cifrado de datos, etc.

Uso del almacén de claves

A través de estos componentes, cualquier instancia de Azure Key Vault permite atajar los siguientes problemas según, DocsMicrosoft (2022):

© Universidad Internacional de La Rioja (UNIR)

Administración de secretos	Azure Key Vault puede almacenar de forma segura (mediante HSM) y controlar estrechamente el acceso a *tokens,* contraseñas, certificados, claves de API y otros secretos.
Administración de claves	Azure Key Vault es una solución de administración de claves basada en la nube, que facilita la creación y el control de las claves de cifrado utilizadas para cifrar los datos. Servicios de Azure como App Service se integran directamente con Azure Key Vault y pueden descifrar secretos sin necesidad de conocer las claves de cifrado.
Administración de certificados	Azure Key Vault también es un servicio que permite aprovisionar, administrar e implementar fácilmente certificados SSL y TLS públicos y privados para su uso con Azure y los recursos internos conectados. También puede solicitar y renovar certificados TLS a través de asociaciones con entidades de certificación, lo que proporciona una solución sólida para la administración del ciclo de vida de los certificados.

Tabla 10. Problemas que ataja Azure Key Vault. Fuente: adaptado de página de DocsMicrosoft, 2022.

Docsmicrosoft (2022) también recomienda los procedimientos de seguridad para el uso de Azure Key Vault que figuran en la Tabla 11.

© Universidad Internacional de La Rioja (UNIR)

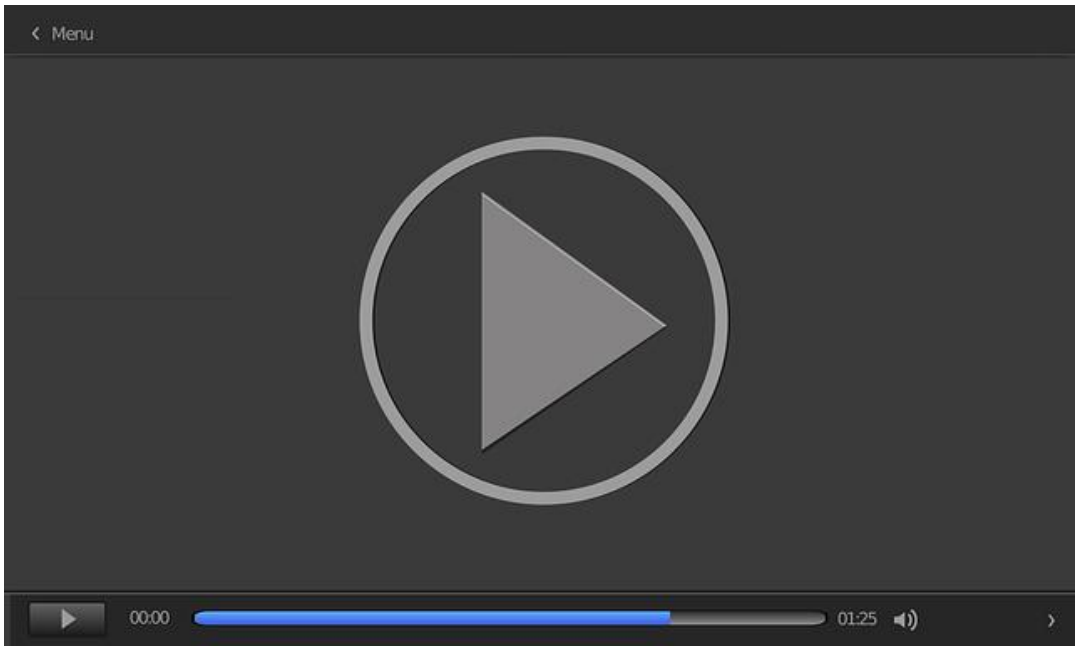
Accesos	Conceda acceso a usuarios, grupos y aplicaciones en un ámbito concreto. Use los roles predefinidos de RBAC. Por ejemplo, para conceder acceso a un usuario para administrar los almacenes de claves, se le asignaría el rol predefinido de Colaborador de almacén de claves en un ámbito específico. En este caso, el ámbito sería una suscripción, un grupo de recursos o, simplemente, un almacén de claves específico. Si los roles predefinidos no se ajustan a sus necesidades, puede definir roles propios.
Controle a qué tienen acceso los usuarios	El acceso a un almacén de claves se controla a través de dos interfaces independientes: **plano de administración y plano de datos.** Los controles de acceso del plano de administración y del plano de datos funcionan de forma independiente. Use **RBAC** para controlar a qué tienen acceso los usuarios. Por ejemplo, si quiere conceder a una aplicación los derechos para usar las claves de un almacén de claves, solo necesita conceder permisos de acceso al plano de datos mediante directivas de acceso al almacén de claves. Esta aplicación no requiere acceso al plano de administración. Por el contrario, si quiere que un usuario pueda leer las propiedades y etiquetas del almacén, pero que no acceda a las claves, los secretos o los certificados, puede concederle acceso de lectura mediante RBAC. No se requiere acceso al plano de datos.
Guarde los certificados en el almacén de claves	Azure Resource Manager puede implementar de manera segura los certificados almacenados en Azure Key Vault cuando se implementan las máquinas virtuales de Azure. Al establecer directivas de acceso adecuadas para el almacén de claves, también controla quién obtiene acceso al certificado. Otra ventaja es que administra todos los certificados desde el mismo sitio en Azure Key Vault.
Asegúrese de que puede recuperar almacenes de claves u objetos de almacén de claves si se eliminan	La eliminación de almacenes de claves u objetos de almacén de claves puede ser involuntaria o malintencionada. Habilite las características de protección de purga y eliminación temporal de Key Vault, especialmente para las claves que se usan para cifrar datos en reposo. La eliminación de estas claves es equivalente a la pérdida de datos, por lo que puede recuperar almacenes y objetos de almacén eliminados si es necesario. Practique las operaciones de recuperación de Key Vault de forma periódica.

Tabla 11. Procedimientos de seguridad al usar Azure Key Vault. Fuente: adaptado de la página de Docsmicrosoft, 2022.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el vídeo *AWS* veremos otra arquitectura de servicios en la nube, la de Amazon Web Services.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=21dd0435-fdd4-4b16-8e2d-adcb0113a68e

© Universidad Internacional de La Rioja (UNIR)

9.6. Referencias bibliográficas

DocsMicrosoft. (2022). *¿Qué es Azure Entra ID?* https://docs.microsoft.com/es-es/learn/modules/manage-users-and-groups-in-aad/2-create-aad

DocsMicrosoft. (2022). *¿Qué es Azure RBAC?* https://docs.microsoft.com/es-es/learn/modules/secure-azure-resources-with-rbac/2-rbac-overview

DocsMicrosoft. (2022). *Creación de una suscripción de Azure adicional.* https://docs.microsoft.com/es-es/learn/modules/azure-architecture-fundamentals/management-groups-subscriptions

DocsMicrosoft. (2022). *Creación y administración de grupos.* https://docs.microsoft.com/es-es/learn/modules/manage-users-and-groups-in-aad/4-groups

DocsMicrosoft. (2022). *Descripción de los distintos tipos de modelos en la nube.* https://docs.microsoft.com/es-es/learn/modules/fundamental-azure-concepts/types-of-cloud-computing

DocsMicrosoft. (2022). *Directorios, suscripciones y usuarios.* https://docs.microsoft.com/es-es/learn/modules/manage-users-and-groups-in-aad/2-create-aad

DocsMicrosoft. (2022). *Instrucciones para configurar Azure Key Vault.* https://docs.microsoft.com/es-es/learn/modules/configure-and-manage-azure-key-vault/2-key-vault-usage

DocsMicrosoft. (2022). *Introducción a las suscripciones, los grupos de administración y los recursos de Azure.* https://docs.microsoft.com/es-es/learn/modules/azure-architecture-fundamentals/overview

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

DocsMicrosoft. (2022). *Personalización de la facturación para satisfacer sus necesidades*. https://docs.microsoft.com/es-es/learn/modules/azure-architecture-fundamentals/management-groups-subscriptions

DocsMicrosoft. (2022). *Recursos de Azure y Azure Resource Manager.* https://docs.microsoft.com/es-es/learn/modules/azure-architecture-fundamentals/resources-resource-manager

DocsMicrosoft. (2022). *Suscripciones de Azure.* https://docs.microsoft.com/es-es/learn/modules/azure-architecture-fundamentals/management-groups-subscriptions

DocsMicrosoft. (2022). *Uso de roles para controlar el acceso a los recursos.* https://docs.microsoft.com/es-es/learn/modules/manage-users-and-groups-in-aad/5-manage-aad-roles

DocsMicrosoft. (2022). *Visualización de usuarios.* https://docs.microsoft.com/es-es/learn/modules/manage-users-and-groups-in-aad/3-users

© Universidad Internacional de La Rioja (UNIR)

Protección de usuarios de Azure Entra ID con Multi-Factor Authentication

Protección de usuarios de Microsoft Entra con autenticación multifactor. (s. f.). https://learn.microsoft.com/es-es/training/modules/secure-aad-users-with-mfa/

Azure AD multifactor authentication (MFA) proporciona seguridad adicional a las identidades al requerir dos o más elementos para una autenticación completa.

© Universidad Internacional de La Rioja (UNIR)

Protección de la aplicación con OpenID Connect y Azure AD

OpenID Connect en la plataforma de identidad de Microsoft. (s. f.). https://learn.microsoft.com/es-es/entra/identity-platform/v2-protocols-oidc

Use OpenID Connect es la aplicación para que los usuarios puedan iniciar sesión de forma segura con identidades de Azure AD.

© Universidad Internacional de La Rioja (UNIR)

Acceso seguro a las aplicaciones con servicios de identidad de Azure

Control de seguridad: identidad y control de acceso. (s. f.). https://learn.microsoft.com/es-es/security/benchmark/azure/security-control-identity-access-control

Obtenga información sobre cómo administrar y proteger las identidades con Azure Entra ID. Vea también cómo el inicio de sesión único, la autenticación multifactor y el acceso condicional les permite a los usuarios acceder de forma segura a recursos y aplicaciones desde la intranet y desde redes públicas.

© Universidad Internacional de La Rioja (UNIR)

Introducción al firewall de aplicaciones web de Azure

¿Qué es el firewall de aplicaciones web de Azure? (s. f.). https://learn.microsoft.com/es-es/azure/web-application-firewall/overview

Descripción de la manera en que Azure Web Application Firewall protege las aplicaciones web de Azure frente a ataques comunes, incluidas sus características, la forma en que se implementa y los casos de uso comunes.

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Qué tres componentes incorpora Azure Key Vault?

A. Almacenes

B. Secretos

C. Claves

D. Todas las anteriores.

2. ¿Cuál de las opciones siguientes se puede utilizar para administrar la gobernanza en varias suscripciones de Azure?

A. Recursos.

B. Grupos de recursos.

C. Grupos de administración.

D. Ninguna de las anteriores.

3. ¿Cuál de opciones siguientes es una unidad lógica de servicios de Azure asociada a una cuenta de Azure?

A. Subscripción de Azure.

B. Grupo de administración.

C. Grupo de recursos.

D. Ninguna de las anteriores.

4. ¿Cuál de las siguientes propiedades no se aplica a los grupos de recursos?:

A. Los recursos solo pueden incluirse en un grupo de recursos

B. Control de acceso basado en rol

C. Se pueden anidar.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

5. ¿Cuál de las siguientes afirmaciones sobre una suscripción de Azure es válida?

A. El uso de Azure no requiere una suscripción.

B. Una suscripción de Azure es una unidad lógica de servicios de Azure.

C. Se puede requerir suscripción o no.

D. Todas las anteriores son ciertas.

6. ¿Qué información proporciona un elemento Action en una definición de roles?

A. Un elemento Action facilita las capacidades de administración que están permitidas.

B. Un elemento Action determina qué datos puede manipular el rol.

C. decide a qué recurso se aplica el rol.

D. Todas las anteriores.

7. ¿Cómo se usa NotActions en una definición de roles?

A. NotActions se restan de Actions para definir la lista de operaciones permitidas.

B. NotActions se consulta después de Actions para denegar el acceso a una operación específica.

C. NotActions permite especificar una única operación que no está permitida.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

8. ¿Qué es una definición de roles en Azure?

A. Una colección de permisos con un nombre que se puede asignar a un usuario, grupo o aplicación.

B. La colección de usuarios, grupos o aplicaciones que tienen permisos para un rol.

C. El enlace de un rol a una entidad de seguridad en un ámbito específico para conceder acceso.

D. Todas las anteriores son ciertas.

9. Un administrador quiere asignar un rol para permitir a un usuario crear y administrar recursos de Azure, pero sin poder conceder acceso a otros usuarios. ¿Cuál de los siguientes roles integrados admitiría esta posibilidad?

A. Propietario.

B. Colaborador.

C. Lector.

D. Ninguna de las anteriores.

10. ¿Qué es el orden de herencia para el ámbito en Azure?

A. Grupo de administración, grupo de recursos, suscripción, recurso.

B. Grupo de administración, suscripción, grupo de recursos, recurso.

C. Suscripción, grupo de administración, grupo de recursos, recurso.

D. Ninguna de las anterioresPrincipio del formulario NNoN.

© Universidad Internacional de La Rioja (UNIR)